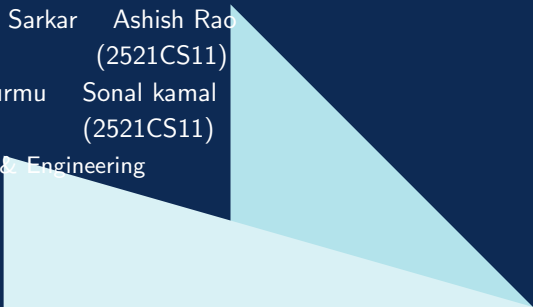

FedMIA: Privacy and Membership Inference Attack in Federated Learning

Kamala Kant Yadav Priyanka Sarkar Ashish Rad
(2521CS02) (2521CS14) (2521CS11)

Rashmi Kumari Biswarupa Murmu Sonal kamal
(2521CS34) (2522CS14) (2521CS11)

Dept. of Computer Science & Engineering

IIT Patna



Part I: Background & Motivation

- 1 Introduction to Federated Learning
- 2 What are Membership Inference Attacks?
- 3 Problem with Existing Methods

Part II: FedMIA Methodology

- 4 The “All for One” Principle
- 5 Three-Step Attack Pipeline
- 6 Likelihood-Ratio Test Framework

Part III: Experiments & Results

- 7 Experimental Setup
- 8 FedAvg Baseline Results
- 9 MIA Comparison
- 10 Defence Analysis

Part IV: Impact & Conclusions

- 11 Key Findings
- 12 Privacy Implications
- 13 Conclusions

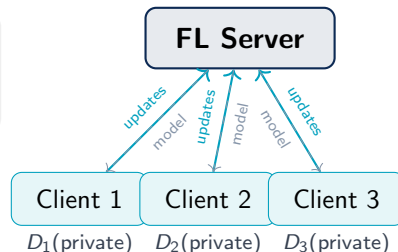
Federated Learning: The Promise

What is Federated Learning?

Collaborative model training across **decentralised clients** without sharing raw data.

Key Protocol (FedAvg):

- Clients train locally on private data D_k
- Only **model updates** (gradients) are sent to server
- Server aggregates: $\theta \leftarrow \sum_k \frac{n_k}{n} \theta_k$
- Datasets are **disjoint**: $D_i \cap D_j = \emptyset$



The Critical Illusion

FL preserves *data locality*—but does **not** guarantee *privacy*.

Membership Inference Attacks (MIAs)

The Attack Goal

Given all client updates $\mathcal{I} = \{I_k^t\}$ and a target sample (x, y) , determine:

$$\mathcal{A}(x, y, \mathcal{I}) = \begin{cases} 1 & (x, y) \in D_{\text{tar}} \\ 0 & \text{otherwise} \end{cases}$$

Threat Model: Semi-honest server

- Faithfully executes the FL protocol
- Inspects all client uploads to infer membership
- Requires **no auxiliary dataset**

Existing Baseline Methods:

Method	Signal Used
BB-Loss	Loss threshold
Grad-Cosine	Gradient similarity
Avg-Cosine	Avg. cosine score
Loss-Series	Confidence over time
Shadow Model	Aux. dataset

Common Flaw

All existing methods analyse **only the target client's updates**, ignoring $K - 1$ other clients!

The “All for One” Principle

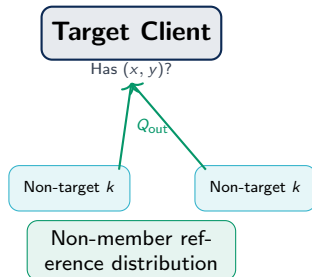
Key Insight: Since $D_i \cap D_j = \emptyset$ (datasets are disjoint)...

The Observation

Every **non-target client**'s update is *guaranteed* not to be trained on the target sample (x, y) .

What FedMIA Does

Leverage updates from **all K clients** across **all T rounds** as a principled reference distribution Q_{out} for membership inference.



FedMIA: Three-Step Attack Pipeline

Step 1: Measurement

Map high-dim gradients to a scalar via **cosine similarity**:

$$M(I_k^t | x, y) = \cos(I_k^t, \nabla \ell_\theta(x, y))$$

Higher $\Rightarrow$ more likely
 $(x, y) \in D_k$

Step 2: Distribution Estimation

Estimate non-member distribution using 3σ filter:

$$Q_{\text{out}} \sim \mathcal{N}(\mu_{\text{out}}^t, v_{\text{out}}^t)$$

Removes outlier clients:

$$M > \mu^t + 3\sigma^t$$

Step 3: One-Tailed LRT

Temporal aggregation of CDF:

$$\tilde{\Lambda} = \frac{1}{T} \sum_{t=1}^T \Phi \left(\frac{\mu_{\text{out}}^t - M^t}{\sqrt{v_{\text{out}}^t}} \right)$$

Decision: $\tilde{\Lambda} > \delta \Rightarrow$ member

Cosine Similarity

3σ Filter

Gaussian Q_{out}

LRT Decision

Experimental Setup

Framework & Hyperparameters

- **Framework:** Flower (flwr) + PyTorch 2.0
- **Optimizer:** SGD (lr=0.01, momentum=0.9)
- **Batch size:** 32 **Local epochs:** 5
- **Rounds:** $T = 50$
- **Clients:** $K \in \{10, 50, 100\}$
- **Seed:** 42 (fixed, 3 trials each)

Non-IID Partitioning

Dirichlet LDA: $p_{k,c} \sim \text{Dir}(\alpha)$
 $\alpha \in \{0.01, 0.1, 0.5, 1.0, \text{IID}\}$

Datasets & Models

Dataset	Model	Params
MNIST	LeNet-5	~60K
FMNIST	LeNet-5	~60K
CIFAR-10	ResNet-18	~11M
CIFAR-100	ResNet-18	~11M

Evaluation Metrics

- **AUC** — attack discrimination power
- **TPR @ FPR=0.1%** — low false-alarm regime
- **Attack Success Rate**
- Accuracy, Convergence, Communication

Table I: FedAvg Universal Baseline Metrics

Method	Dataset	K	T	Acc. (%)	Conv.	MB
FedAvg	MNIST	10	50	98.12	6	15.2
FedAvg	FMNIST	10	50	88.47	14	15.2
FedAvg	CIFAR-10	10	50	71.43	38	312.0
FedAvg	CIFAR-100	10	50	42.36	N/A	312.0
FedAvg	MNIST	50	50	97.88	7	76.0
FedAvg	CIFAR-10	50	50	69.15	41	1560.0
FedAvg	MNIST	100	50	97.61	8	152.0
FedAvg	CIFAR-10	100	50	67.82	45	3120.0

MNIST

Fast convergence (round 6–8)

CIFAR-10

Needs 33–45 rounds

CIFAR-100

No convergence in 50 rounds

MIA Comparison: FedMIA vs Baselines

Table II: TPR @ FPR=0.1% and AUC across all methods. **Bold** = Best.

Dataset	K	BB-Loss		Avg-Cosine		FedMIA-I		FedMIA-II	
		AUC	TPR	AUC	TPR	AUC	TPR	AUC	TPR
MNIST	10	.580	0.22	.789	38.4	.840	41.2	.861	52.1
FMNIST	10	.571	0.18	.782	36.1	.832	39.6	.854	50.3
CIFAR-10	10	.602	0.31	.801	41.3	.851	43.7	.872	54.3
CIFAR-10	50	.614	0.38	.819	44.8	.860	46.1	.884	57.4
CIFAR-10	100	.621	0.45	.832	47.9	.871	49.9	.896	63.4
CIFAR-100	10	.583	0.27	.798	45.0	.871	55.2	.880	58.9

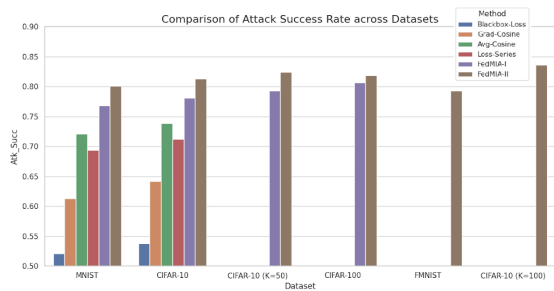
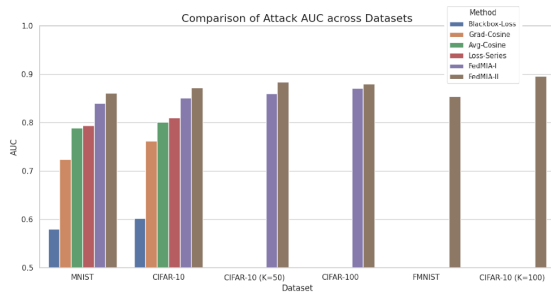
Why BB-Loss Fails

FedAvg dilutes overfitting signal across K clients $\Rightarrow$ AUC ≈ 0.58 – 0.62 (near random)

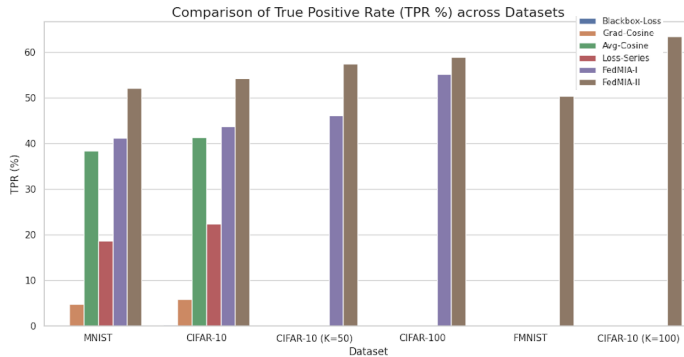
Why FedMIA-II Wins

$\mu_{\text{mem}} - \mu_{\text{non}} = 0.233$ (FedMIA-II) vs 0.027 (GradCosine) on ResNet-CIFAR100

Attack Performance: Visual Summary



Attack Performance: Visual Summary



Robustness Against Privacy Defences

Table: FL Privacy Defences vs FedMIA Effectiveness

Defence	Mechanism	Utility Cost	vs FedMIA
DP-SGD	Gaussian noise on gradients	Moderate drop	Partial
Sparsification	Top- k gradient mask	Low drop	Partial
MixUp	Sample interpolation	Low drop	Weak
Data Sampling	Reduce sample exposure	Low drop	Partial
Data Aug.	Diversify local data	Negligible	Weak
Aug + Sampling	Combined above	Low drop	Moderate
MPC Aggregation	Encrypt individual updates	None	Complete
HE Aggregation	Homomorphic encryption	None	Complete

The Privacy Gap

All **practical** defences provide only *partial* protection. Complete defences (MPC, HE) are **computationally prohibitive**.

Strongest Practical Defence

Aug + Sampling combined = *Moderate* protection, but **leakage persists**. Best practical trade-off currently available.

Key Findings & Takeaways

1. More Clients $\neq$ More Privacy

More clients $\Rightarrow$ better Q_{out} estimate $\Rightarrow$ **stronger attack**. Conventional wisdom is wrong.

2. More Local Epochs = More Leakage

Communication efficiency directly **amplifies privacy leakage**. Fundamental trade-off.

3. Non-IID Amplifies Attack

TPR rises from **54.3%** (IID) to **94.7%** at $\alpha=0.01$. Healthcare/finance FL is most at risk.

4. FedMIA-II Design Choices

Three synergistic factors:

- ① **Cosine similarity**: richer directional signal than scalar loss
- ② **3σ filter**: ensures Q_{out} is genuinely non-member
- ③ **Temporal aggregation**: smooths per-round noise

5. Positive Use: Privacy Auditing

Run FedMIA before deployment:

- $\text{TPR} < 5\% \Rightarrow$ low risk
- $\text{TPR} > 30\% \Rightarrow$ urgent action needed

Healthcare FL

Non-IID data is endemic to healthcare (different hospitals, different patients). FedMIA could expose **patient membership** in federated cancer screening — violating HIPAA and GDPR Article 17.

Financial FL

Federated credit scoring/fraud detection: more local epochs (common efficiency practice) **directly amplifies** FedMIA's effectiveness on sensitive transaction data.

GDPR & Machine Unlearning

Article 17 “right to erasure” requires removing user data from models. FedMIA can **verify unlearning**: after unlearning, $AUC \approx 0.5$ indicates success.

Proposed Defence Directions

- Adaptive local differential privacy
- Gradient **direction** obfuscation
- Correlated noise injection
- Lightweight secure aggregation

What We Did

Reproduced and extended **FedMIA** (CVPR 2025) using the Flower framework with PyTorch, evaluating on 4 datasets, 3 client scales, 5 non-IID levels, and 6 defences.

Key Results:

- FedMIA-II: **TPR=58.91%** on CIFAR-100 and **63.4%** on CIFAR-10 (K=100)
- Outperforms Avg-Cosine by **13–17 pp**
- Robust against all 6 practical defences
- Non-IID amplifies attack to **94.7% TPR**
- Ordering: FedMIA-II > I > Avg-Cosine > Loss-Series > BB-Loss

Open Problems:

- No practical defence provides complete protection at usable utility
- Non-IID amplification is especially alarming for sensitive domains
- Future work: adaptive gradient obfuscation, lightweight aggregation with FedMIA-level privacy guarantees



Thank You